

Título de Plática: Clasificación de incidentes.

La norma ISO 27001 define un incidente de seguridad, como **“una sola o una serie de eventos de seguridad de la información no deseados o inesperados que tienen una elevada probabilidad significativa de comprometer las operaciones de negocio y amenazando la seguridad de la información”**.

Gestionar los incidentes de seguridad según la norma ISO 27001 consta de estas diferentes medidas:



La información generada para resolver el incidente debe quedar registrada, por lo que si el problema vuelve a ocurrir en el futuro siempre se puede contar con la referencia, contando con la solución sin tener que perder tiempo.

Clasificación de los incidentes:

Existe muchas formas de clasificar los incidentes, pero lo habitual es considerar dos parámetros:

Impacto: es el daño que se causa en la organización.

Urgencia: velocidad con la que la empresa necesita corregir el incidente.

La intersección de los parámetros nos permite establecer la prioridad de cada incidente, por lo que de esta forma podemos generar la siguiente tabla de valores:

Donde los incidentes de valor 1 son críticos ya que la relación entre la urgencia y el impacto son elevados, por lo que se establece que los mejor es obtener valores 2, 3, 4 ó 5.

Algunas categorías comunes de incidentes de seguridad según ISO 27001:

Impacto \ Urgencia	Alto	Medio	Bajo
Alto	1	2	3
Medio	2	3	4
Bajo	3	4	5

Incidentes de Confidencialidad: Implican la divulgación no autorizada de información sensible, la confidencialidad es crucial para proteger la información sensible de la organización y de los clientes.

Incidentes de Integridad. Afectan la exactitud y confiabilidad de la información, La integridad asegura que la información sea precisa y confiable, lo cual es esencial para la toma de decisiones informadas.

Incidentes de Disponibilidad. Afectan la disponibilidad de sistemas y servicios, la disponibilidad garantiza que los sistemas y servicios estén accesibles cuando se necesiten.

Incidentes de Cumplimiento. Es el incumplimiento de leyes, regulaciones o políticas internas, es esencial para evitar sanciones legales y mantener la reputación de la organización.

La correcta clasificación de incidentes permite a las organizaciones priorizar su respuesta y asignar los recursos adecuados para mitigar el impacto de los incidentes de seguridad. Además, ayuda a identificar patrones y tendencias que pueden informar futuras mejoras en la seguridad de la información.

¿Qué opinas del tema de hoy? ¡Comparte alguna experiencia similar al tema de hoy! ¿Puedes prevenir algún riesgo similar en tú trabajo o en tu hogar?

IBM: M57723

Nombre: **María del Carmen Bazán Arredondo.**

Fecha: **09-Junio-2025**

Recuerda **vivir** las
TRES RESPONSABILIDADES de
seguridad y **cumple**
constantemente las
10 REGLAS CRÍTICAS

